M1 Submission Package

Secure Inter-Campus Communication Network | Secure Communication Protocols 1305301 Group 03 | First Semester 2026/2027 | Prepared 2026-11-07

Team

Student ID	Confirmed original name
2350906014	الاء يزن احمد الزعبي
2300906110	بغداد ثامركساب بني خالد

Repository and reproducible evidence

Resource	Clickable link
GitHub repository	https://github.com/alaayznn/scp-secure-inter-campus-g03
Real WAN capture	evidence/pcaps/M1_baseline_wan.pcap
Reproducible results	evidence/sanitized_logs/M1_runtime_checks.json

The six required M1 documents follow this cover, with PDF bookmarks. Editable sources, lab files, commands and the real capture are retained in the repository. No M2 implementation is included.

Observed baseline

Observed item	Verified result
WAN capture	gw-hq eth1, 172.16.3.10/24; 10 packets, 1221 bytes.
HTTP time	07/11/2026 20:37:28 UTC / 23:37:28 Asia/Amman
Request / response	Frame 4: GET /baseline.txt. Frame 6: HTTP 200 and SCP-M1-G03-HTTP-CLEAR in readable payload.
Validation	44 runtime checks PASS; six healthy nodes, isolated networks and no VPN.
SHA-256	9d2a6dc6646d15deb81ebe6109535b3dc6d3cbb3dbfad7ccd39f3aea7c53ee9d

Readable HTTP is the intended before-VPN baseline; it does not demonstrate later security controls. Results are from a scripted run requested by 2350906014; independent member review/retest is not claimed.

Acceptance items requiring clarification

No Starter Kit was supplied; lab/ was prepared locally, not provided by the instructor. Acceptance of this replacement is not recorded. The assignment requires a private repository; the team requested Public visibility for account-free access. Approval of that exception is not recorded. The original M1 deadline is 06/11/2026; no extension is assumed.

Two-member approval is team-confirmed. Technical design/baseline evidence is included. The M1 tag remains withheld pending the listed acceptance items and member review; no further approval is asserted.

Requirements and Acceptance

Secure Inter-Campus Communication Network | Group 03 | M1 design

Scope and authority

This project protects a two-campus university network across an untrusted WAN. M1 fixes requirements, topology, trust, PKI and protocol designs, threats, responsibilities and an observable HTTP baseline. This package prepares M1 only. It does not implement the M2 PKI, crypto tool or TLS portal, or the M3 VPN/KDC/attacks.

Authority: assignment v1.0, pp. 1-11. Section 9 (p. 7) defines M1; sections 7-8 (pp. 5-7) define cumulative FR/SR; section 12 (p. 10) defines the final repository structure. Mandatory requirements below come from that assignment; numerical design choices are identified as proposals, not extra grading rules.

The instructor Starter Kit was not supplied, according to the user. lab/ is an independently authored reconstruction, not instructor material. The specification prohibits lab/ changes without written approval; equivalence/acceptance of this replacement has NOT been approved. This discrepancy must be resolved before submission. Two members are used with instructor approval reported by the user. The original M1 deadline is 06 November 2026; no extension is assumed.

Functional requirements and traceability

Implementation and acceptance evidence in this table are future work unless explicitly marked M1. R=Requirements; T=Topology; P=PKI; D=Protocol; S=STRIDE; W=TeamPlan, all in docs/M1/.

ID	Required behavior and measurable acceptance	Design / planned evidence
FR01	Build the complete two-tier PKI from an empty directory by script. A second clean build follows the same profiles and succeeds; random keys/serials need not be identical.	P; future build transcript and inventory; T1/T13.
FR02	Issue from CSRs using named profiles; every legitimate chain passes openssl verify with intended purpose, SAN and extensions. Rogue chain fails.	P; certificate text, verification outputs; T1.
FR03	Revoke a certificate, publish a fresh CRL; nginx rejects revoked staff and strongSwan rejects revoked gateways.	P/D; dated CRL and refusal logs; T4/T8.
FR04	Final portal HTTPS only; HTTP redirects except documented CRL distribution endpoint; HTTPS supplies HSTS.	D; curl headers, testssl; T6. M1 HTTP is a deliberate baseline exception.
FR05	/staff/ requires valid client certificate, displays/logs its identity; missing or revoked certificate refused generically.	D; valid/absent/revoked results; T3/T4.
FR06	Final lab starts certificate-authenticated IKEv2 tunnel automatically. M1 must NOT start it.	T/D; swanctl --list-sas plus startup log in M3; T7.

ID	Required behavior and measurable acceptance	Design / planned evidence
FR07	Tunnel selectors only 10.3.1.0/24 <-> 10.3.2.0/24. Non-matching traffic is not protected by that child SA.	T/D; installed policies and WAN capture; T7/T10.
FR08	Tool signs/verifies, MACs/verifies, AEAD encrypts/decrypts, agrees keys, rejects tampering.	D (algorithm policy); future known-answer and modified-byte tests; T2.
FR09	KDC authenticates staff and issues TGT then service ticket; wrong credentials refused generically.	D; AS/TGS logs and positive/negative runs; T11.
FR10	Client/service mutually authenticate and confirm fresh session key; duplicate authenticator refused.	D/S; AP transcript and replay refusal; T11/T12b.
FR11	README rebuilds system from clean machine with ordered scripts and real evidence.	R/W; M1 lab recipe, later clean rebuild; T13.
FR12	Weak TLS/PSK/no-freshness variants stay under attacks/, never loaded into final services.	S/W; configuration review and controlled T12a/T12b.

Mandatory security constraints

These are cumulative project constraints relevant to M1 design, not claims of implementation.

SR	Design acceptance and planned verification
SR01	Approved AEAD, SHA-256+, ECDSA/Ed25519, RSA >=3072/PSS for new signatures, ECDH/X25519; library primitives only; CSPRNG and unique per-key nonces. Verify code and tamper tests later.
SR02	Offline encrypted Root; pathlen 1/0; proper KU/EKU and end-entity SAN; random unique serials. Verify profile and certificate inventory.
SR03	Dated CRLs enforced by nginx and strongSwan. Test valid/revoked/missing/expired cases; document CRL vs OCSP and fail policy.
SR04	TLS >=1.2, TLS 1.3 enabled, AEAD/PFS only, leaf+intermediate chain, HSTS, no HIGH/CRITICAL testssl results.
SR05	/staff/ client verification, verify depth, CRL, subject logging and generic rejection. T3/T4.
SR06	Lab DNS-spoof/rogue-CA MITM refused; insecure verification-off comparison confined to attacks/. T5.
SR07	Certificate-only IKEv2, pinned identity, explicit AEAD/ECDH proposals, PFS, rekey and DPD. T7/T8 and weak-proposal refusal.
SR08	Final WAN only UDP 500/4500 and ESP; fail-closed LAN forwarding on tunnel loss. T9/T10. M1 scoped clear HTTP/ICMP is removed in M3.

SR	Design acceptance and planned verification
SR09	AS/TGS/AP with authenticated tickets, AAD, HKDF keys, bounded freshness, replay cache, mutual authentication; no transmitted long-term keys.
SR10	Separate weak protocol replay succeeds, same replay fails after fix. T12a/T12b; not run in M1.
SR11	No secrets/.env/p12/key logs/PSK in Git; mode 600 private keys; full-history scan before tags.
SR12	Real WAN before/after captures with known-string search; later isolated TLS key-log exercise, followed by deleting key log.
SR13	TLS 1.0/1.1, non-AEAD/non-PFS and weak IKE offers rejected. Planned later negative tests.
SR14	Unified results include expected/actual, date, actual tester, commands, evidence and fix notes. No invented PASS or contributor.

Actors and use cases

Actor	Preconditions / action	Success / refusal
Staff Member	Holds own staff key/certificate and group Root trust; connects from client-br to /staff/. Separately uses its own long-term KDC credential for AS/TGS/AP.	Valid unrevoked certificate shows identity; valid tickets confirm session key. Missing/revoked cert, bad credential, stale or duplicate authenticator rejected.
Public Visitor	Trusts group Root and resolves portal name in the lab; opens public /.	HTTPS public content without client certificate. Untrusted server or old TLS fails; /staff/ remains restricted. No real external visitor access is exposed by M1.
Administrator	Authorized local operator; maintains profiles, CRLs, trust stores and gateway policy.	Builds inventory, revokes cert, atomically publishes CRL, checks refusal logs, rebuilds via README. Root signing occurs only offline; secrets excluded.

M1 acceptance gates

Gate	Acceptance / current state
A1	Six required PDFs exist and are visually reviewed; editable sources retained. Status is recorded in evidence/sanitized_logs/M1_static_review.json.
A2	Group 03 names/addresses agree across diagrams, Compose and live node inspection. Runtime route/isolation checks are recorded in evidence/sanitized_logs/M1_runtime_checks.json.
A3	>=8 lab-specific threats with likelihood, impact, controls and planned checks. See S.
A4	PASS: six healthy nodes, client-br HTTP to web-hq and real gw-hq WAN capture. evidence/pcaps/M1_baseline_wan.pcap contains 10 packets, readable GET at frame 4 and HTTP 200/body at frame 6.

Gate	Acceptance / current state
A5	PASS for scripted execution: capture session records UTC, eth1 WAN interface, filter and commands; runtime log records requester and results. Independent member retest/review remains unclaimed.
A6	Assignment requires private GitHub plus final timestamped M1 tag. Team requested Public instead; anonymous reading is verified. Instructor acceptance of this visibility exception and M1 tag remain pending. Secrets are scanned; no tag is created while gates remain unresolved.
A7	Starter Kit replacement discrepancy disclosed and acceptance clarified; member data confirmed. Names/IDs received; kit approval remains unresolved.

Optional choices and exclusions

PDF rather than XLSX for STRIDE is explicitly permitted. Additional threats and machine-readable static validation are optional improvements. Suggested interface names/ports in section 7.1 are not all mandatory; gateway swanctl paths are fixed. Future-stage directories reserve structure only. No future-stage certificates, keys, executable protocol, attack or VPN configuration are delivered as working M1 functionality.

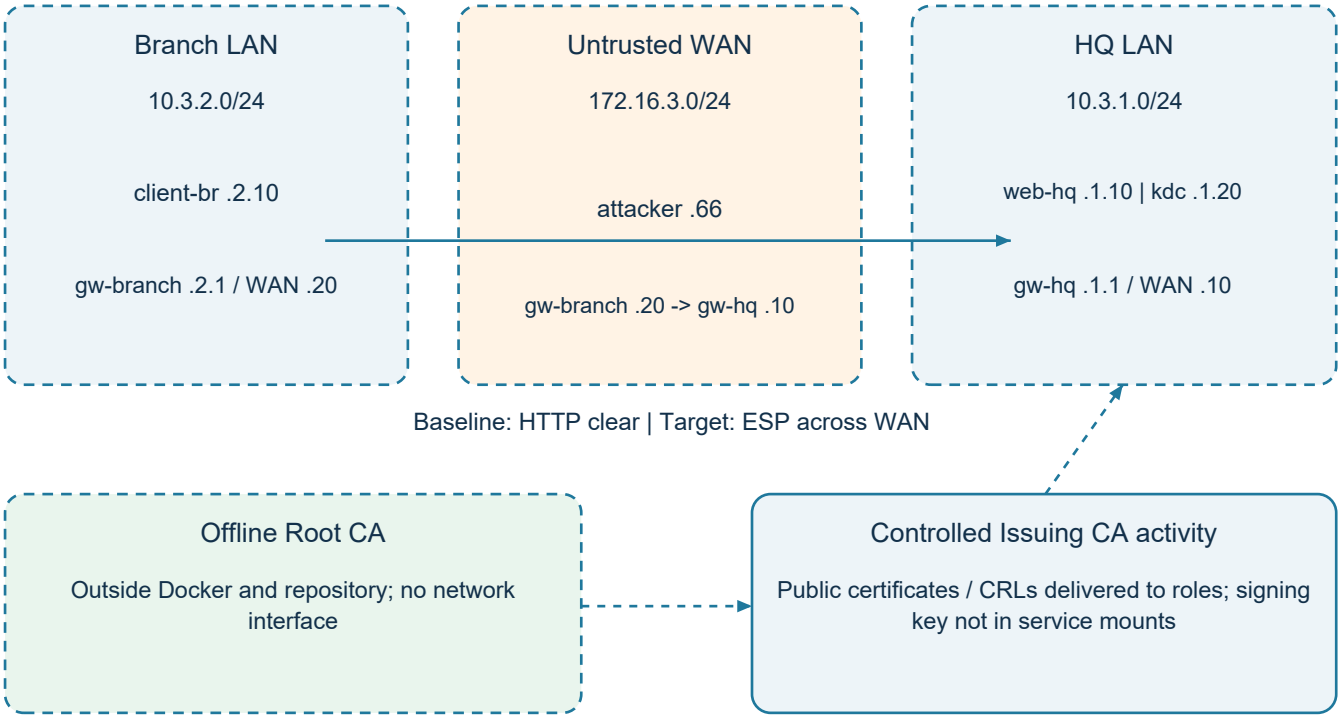
The real baseline uses internal, isolated Docker bridges with masquerading disabled. Docker's internal-subnet filter also blocked legitimate off-subnet packets travelling to a router container. lab/host_l2_transit.py adds only same-project-bridge, lab-address rules in DOCKER-USER. No global firewall policy, bridge sysctl, external interface or NAT rule is changed. Both the rules and live egress restrictions are checked by the M1 runner.

Topology and Trust Boundaries

Group 03 | Address component G=3 | M1 baseline and target design

Network view

The diagram separates four trust domains: Branch LAN, untrusted WAN, HQ LAN, and offline Root CA. Only six nodes run in Docker; CA signing is an administrative activity, not a seventh service node.



Network	CIDR / reserved IPAM gateway	Trust and ownership
WAN	172.16.3.0/24 / .254	Untrusted; both gateways and authorized attacker.
HQ LAN	10.3.1.0/24 / .254	HQ services; use gw-hq .1 for cross-campus routes.
Branch LAN	10.3.2.0/24 / .254	Staff client; use gw-branch .1 for HQ routes.
Offline CA	No lab interface/address	Encrypted Root key outside repository and every Docker bind mount.

The .254 addresses are reserved by Docker IPAM, not campus routing. Gateway mode isolated assigns no IPv4 address to the host bridge. Endpoints delete any default route and use only explicit lab routes; gateways have no external default. Interface names are discovered by assigned IPv4, never assumed eth0. Every network is internal/isolated with masquerading and IPv6 disabled and no published host ports. Docker-host administrators remain trusted.

Docker's internal-subnet filter initially dropped routed packets before the router container received them. A project-owned DOCKER-USER chain now permits only the same input/output SCP bridge and permitted lab

address pairs: campus-to-campus, and attacker-to-Branch/return. All other traffic returns to normal Docker filtering. No host default policy, global sysctl, external interface or NAT rule is changed. Apply lab/host_l2_transit.py after network creation; its read-only --show output is checked during validation.

Six-node inventory

Node / FQDN	Address(es)	Role / attached networks
gw-hq.g03.scp.lab	172.16.3.10; 10.3.1.1	WAN + HQ; route baseline, future VPN endpoint.
gw-branch.g03.scp.lab	172.16.3.20; 10.3.2.1	WAN + Branch; route baseline, future VPN endpoint.
web-hq.g03.scp.lab	10.3.1.10	HQ; baseline HTTP, later TLS portal, CRL and service.
kdc.g03.scp.lab	10.3.1.20	HQ; idle in M1, future KDC.
client-br.g03.scp.lab	10.3.2.10	Branch; HTTP client, future mTLS/Kerberos client.
attacker.g03.scp.lab	172.16.3.66	WAN only; explicit route to Branch via gw-branch, no HQ route.

portal.g03.scp.lab and pki.g03.scp.lab map to 10.3.1.10. Static /etc/hosts entries supply lab resolution; no university DNS is changed. Gateway certificate names and IKE identities use these same FQDNs. Source of group identity: user-confirmed G3, normalized to 03/3.

Permitted flows and baseline routing

Flow	M1 baseline	Future target (design only)
client-br -> web-hq	TCP 80, HTTP GET /baseline.txt; known text SCP-M1-G03-HTTP-CLEAR. ICMP for reachability.	Inner HTTPS TCP 443, protected across WAN by ESP; HTTP redirect and explicit CRL exception.
Branch <-> HQ	Explicit routes via the two gateways. Baseline firewall permits only client-br/web-hq TCP 80 and ICMP plus established replies.	Explicit selectors 10.3.2.0/24 <-> 10.3.1.0/24, encrypted policies required.
client-br -> KDC / service	Not enabled in M1.	TCP 8800 on kdc; TCP 8801 on web-hq; AEAD-protected AS/TGS/AP inside tunnel.
Gateway <-> gateway	No IKE daemon or VPN configuration started.	UDP 500/4500 and ESP (IP protocol 50); certificate-authenticated IKEv2.
attacker -> Branch	Route via gw-branch; baseline forwards attacker-source traffic to Branch for later authorized tests.	Testing foothold remains lab-only; final policy tested separately.
attacker -> HQ	No route on attacker; gw-hq drops non-baseline WAN flows, including routed attacker-source HQ attempts.	HQ unreachable; future T10 scan proves boundary.

Flow	M1 baseline	Future target (design only)
CA -> services	No private CA material mounted. No signing now.	Offline Root -> Issuing certificate/CRL only; controlled public artifact transfer.

web-hq and kdc have 10.3.2.0/24 via 10.3.1.1. client-br has 10.3.1.0/24 via 10.3.2.1 and WAN via gw-branch. gw-hq routes Branch via 172.16.3.20; gw-branch routes HQ via 172.16.3.10. attacker routes only Branch via 172.16.3.20. No NAT is used. Source-address spoofing by a privileged attacker is a baseline risk, not a claimed authentication control.

Target trust decisions

VPN authenticates only pinned gateways, not every certificate signed by the CA. TLS authenticates the portal end-to-end beyond VPN termination; mTLS binds a request to a staff private-key holder, not necessarily a physical person. KDC is separately trusted for ticket/session-key issuance. Root signs only Issuing CA and its CRL; Issuing cannot create subordinate CAs (pathlen 0). CRL signature verification protects authenticity over HTTP but cannot ensure availability or freshness without nextUpdate checks.

After M3 only IKE and ESP should carry campus application traffic on WAN. ARP is normal link-layer housekeeping and is excluded from the application-confidentiality claim. LAN segments remain outside the ESP tunnel: HTTPS and protocol AEAD still matter. Final fail-closed firewall is future work; M1 deliberately permits scoped plaintext so it can be observed.

Verified M1 baseline evidence

Actual capture: gw-hq eth1, assigned 172.16.3.10/24, on 07/11/2026 at 20:37:27 UTC (23:37:27 Asia/Amman). Route: client-br -> gw-branch -> WAN -> gw-hq -> web-hq, and return. All six nodes were healthy; no XFRM policy or charon daemon was running. Capture file: evidence/pcaps/M1_baseline_wan.pcap; 10 packets, 1221 bytes. Frame 4 is GET /baseline.txt from 10.3.2.10 to 10.3.1.10; frame 6 is HTTP 200 with SCP-M1-G03-HTTP-CLEAR. Original campus addresses remain visible on WAN; no NAT or VPN is masking them.

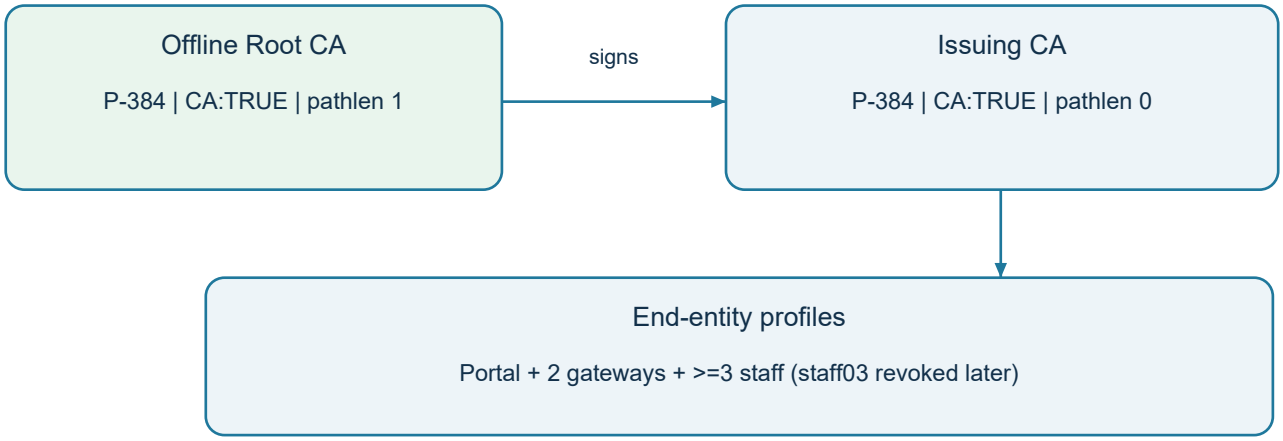
The filter was host 10.3.2.10 and host 10.3.1.10 and tcp port 80. The current interface name is an observation, not a hard-coded assumption for another rebuild. Commands, exact hash, stream and checks are retained in evidence/sanitized_logs/M1_capture_session.txt, M1_runtime_checks.json and M1_baseline_review.md. Independent teammate review is not claimed.

PKI Design

Group 03 | Design only; no certificates or private keys generated

Hierarchy and naming

PKI (Public Key Infrastructure) binds identities to public keys through signed certificates. The offline Root CA signs the Issuing CA certificate and Root CRL only. The Issuing CA signs portal, gateway and staff certificates and its own CRL. Services trust the Root public certificate; servers send leaf plus Issuing certificate, usually omitting the Root trust anchor. CN labels identity; SAN is authoritative for endpoint names.



All key choices below are proposals within specification section 6. KU means Key Usage; EKU means Extended Key Usage; SAN means Subject Alternative Name; BC means Basic Constraints. CA certificates are not end entities. AKI/SKI identify issuer/subject keys; serials are random positive unique 128-bit values checked against the CA database. No real member email addresses are invented: staff SAN emails below are lab-only identities.

Profile / Subject	SAN / key	Extensions / validity
root / CN=AABU SCP Root CA g03	No SAN required; ECDSA P-384	critical BC CA:TRUE,pathlen:1; critical KU keyCertSign,cRLSign; SKI/AKI; no EKU. 1825 days, <=5 years at issuance.
issuing / CN=AABU SCP Issuing CA g03	No SAN required; ECDSA P-384	critical BC CA:TRUE,pathlen:0; critical KU keyCertSign,cRLSign; SKI/AKI; Root CRL DP. 730 days, capped at parent expiry and <=2 years.
portal / CN=portal.g03.scp.lab	DNS portal.g03.scp.lab, pki.g03.scp.lab; ECDSA P-256	critical BC CA:FALSE; critical KU digitalSignature; EKU serverAuth; Issuing CRL DP; SKI/AKI. 365 days <=398 and issuer expiry.
gateway-hq / CN=gw-hq.g03.scp.lab	DNS gw-hq.g03.scp.lab; IP 172.16.3.10; ECDSA P-256	critical BC CA:FALSE; critical KU digitalSignature; EKU id-kp-ipsecIKE (1.3.6.1.5.5.7.3.17), compatibility pending; Issuing CRL DP; SKI/AKI. 365 days <=398.

Profile / Subject	SAN / key	Extensions / validity
gateway-branch / CN=gw-branch.g03.scp.lab	DNS gw-branch.g03.scp.lab; IP 172.16.3.20; ECDSA P-256	Same gateway constraints; exact peer FQDN pinning independent of CA trust. 365 days <=398.
staff01, staff02, staff03 / CN=staffNN	email staffNN@g03.scp.lab; ECDSA P-256	critical BC CA:FALSE; critical KU digitalSignature; EKU clientAuth; Issuing CRL DP; SKI/AKI. 365 days, <=1 year and issuer expiry.

At least THREE staff certificates are mandatory even with the approved two-member group. staff01 and staff02 are distinct lab principals; staff03 is a test principal to be revoked, not a claimed third member. No certificate is shared by people. Planned inventory has Root, Issuing, portal, two gateways and three staff certificates (8 minimum legitimate certificates). Rogue CA/certificate are later isolated attack artifacts, never installed in host/real-browser trust.

Gateway EKU is a proposed purpose-specific restriction, not a substitute for exact identity matching. Test the Ubuntu strongSwan 5.9+ build against id-kp-ipsecIKE and reject staff clientAuth certificates. If this EKU is not enforced by the selected build, document the compatible profile and require explicit gateway-purpose/identity checks before accepting the design. Do not silently broaden trust to every CA-issued leaf.

Secret placement and classification

Artifact	Classification / location / access
Root key and passphrase	SECRET. Encrypted offline storage outside project folder, Docker build context and all /work mounts; signing workstation only; Unix mode 600 and restrictive parent directory. Passphrase entered interactively.
Issuing key / CA database backup	Key SECRET, database INTERNAL. Controlled signing workspace outside service mounts; encrypted backup, mode 600, offline between operations where feasible.
Portal / gateway / staff private keys	SECRET. Per-role runtime secret mounts only in future stages, owner-read/write 600; never mounted wholesale across all six nodes. No secret creation in M1.
Root/Issuing/leaf certificates and CRLs	PUBLIC. Reviewed public certificate/CRL files may enter Git; fingerprints independently checked before trust.
Profiles, topology and configuration	INTERNAL under the assignment's classification. Non-secret lab configuration is currently published at the team's explicit request; acceptance of the Public-repository exception is pending. Lab identifiers are test data.
PCAPs, logs, TLS key logs	Baseline synthetic PCAP INTERNAL; review before commit. Key logs SECRET, never Git, delete after isolated exercise. No real credentials in traffic.

Windows bind-mount permissions do not establish Linux mode 600 by themselves. Future secret creation uses Linux-controlled storage with observed ownership/permissions; Windows ACLs and backup access also checked. Root exclusion is by physical storage placement, not .gitignore alone.

Issuance workflow (planned M2)

1. Create separate encrypted Root and Issuing keys; verify profiles and parent-expiry caps. Root signs only Issuing CA and Root CRL, then goes offline.

2. Generate each end-entity private key at its authorized role, create CSR, validate allowed identity/SAN/profile independently of CSR requests, sign with Issuing CA.

3. Write pki/certs_inventory.md with serial, Subject, SAN, issuer, notBefore/notAfter, profile and revocation state. Inspect extensions and verify chains/purposes.

4. Transfer only role-specific credentials; publish public chains/CRLs; test valid, wrong-name, wrong-purpose, untrusted, expired and revoked credentials. No pki implementation is included in M1.

Revocation and CRL publication

CRL (Certificate Revocation List) is a signed list of revoked serials; OCSP answers per-certificate status online. CRLs work with this offline-capable lab but can be stale. OCSP introduces an online dependency and is not substituted for the mandatory CRL. Soft-fail means accepting a credential when revocation status cannot be checked; this design rejects unknown status.

Proposed Issuing CRL validity: 24 hours; regenerate before half-life and immediately on revocation. Publish atomically at http://pki.g03.scp.lab/crl/issuing.crl (DER for distribution), retain PEM for local validators. Proposed Root CRL: 30 days, refreshed via offline signing before half-life and immediately upon Issuing compromise; publish /crl/root.crl. Both carry thisUpdate, nextUpdate, issuer, CRL number and valid signature. Root and Issuing CRLs are supplied wherever intermediate revocation must be checked.

HTTP CRL distribution is an explicit exception to portal redirect, avoiding a circular TLS-validation dependency. Verify CRL signature, issuer and freshness on import. nginx uses a locally managed PEM bundle via ssl_crl; it does not fetch CRL URLs automatically. Refresh/reload must be monitored. strongSwan strict revocation policy with cached/prefetched CRLs must be tested on the selected build; establish initial CRL availability before protected access.

Missing or expired CRL: refuse new staff authentication and new IKE authentication; alert and refresh rather than continue silently. Existing TLS sessions/IKE SAs may survive a CRL update; revocation procedure invalidates resumptions, closes relevant TLS connections and terminates affected IKE SAs, then verifies reconnect refusal. Missing CRL can prevent nginx reload while old workers still run, so a successful file copy/reload attempt alone is insufficient: check effective policy and stop protected service if freshness cannot be guaranteed.

Revocation exercise: revoke staff03, update/publish CRL, deploy and reload, verify staff01 succeeds and staff03 fails; repeat with a test gateway certificate in later milestones. Evidence includes dated inventory, serial, openssl crl -text, valid nextUpdate, nginx/strongSwan logs and negative tests. Nothing in this plan is reported as executed.

Protocol Design

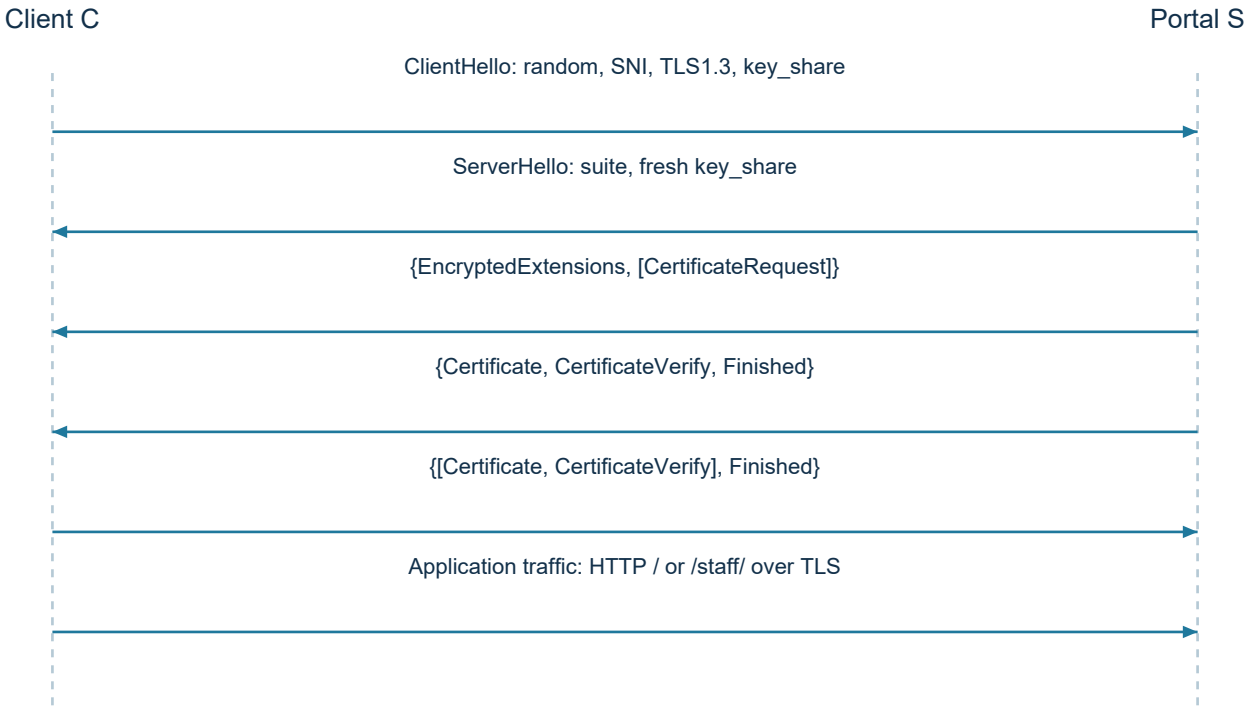
Group 03 | TLS and IKE designs; first Kerberos-style draft | Not implemented

Shared rules

Endpoints use Group 03 identities in Topology/PKI designs. Cryptographic primitives come from OpenSSL, strongSwan and pyca/cryptography, never hand-written. Later crypto tool choices: HMAC-SHA-256, Ed25519 signatures, AES-256-GCM AEAD and X25519 plus HKDF-SHA-256; separate keys by purpose and test known-answer vectors in M2. TLS/IKE use their native key schedules, not the custom protocol below.

TLS 1.3 full handshake as intended

Parties: C=client-br/public visitor; S=web-hq portal.g03.scp.lab. Arrows after ServerHello carry encrypted handshake records. CR=CertificateRequest. A public client may send an empty certificate list; staff must supply a valid chain and prove private-key possession. No 0-RTT; initially disable tickets/resumption so the tested path is an unambiguous full handshake.



ClientHello proposes TLS 1.3, AEAD suites, signature schemes, a fresh random and X25519 key share, SNI=portal.g03.scp.lab. ServerHello selects suite/group and fresh share/random. ECDHE plus HKDF yields handshake then application traffic keys. CertificateVerify signs the transcript; Finished authenticates it with a derived key. An optional HelloRetryRequest is a standard branch to test if group selection requires it; the primary diagram assumes matching groups.

S sends leaf plus Issuing CA. C checks Root trust, SAN hostname, validity, KU/serverAuth and intended revocation policy. C's CertificateVerify proves staff key possession; S validates chain, clientAuth, freshness/CRL and policy. The proposed TLS 1.3 suites are TLS_AES_128_GCM_SHA256 and TLS_AES_256_GCM_SHA384; TLS 1.2 compatibility uses ECDHE-ECDSA-AES128/256-GCM only. TLS below 1.2 and non-AEAD/non-PFS offers fail. Final HSTS is sent over HTTPS; public HTTP redirects except the pki CRL endpoint. These controls are future M2 work.

mTLS for /staff/

mTLS means both peers authenticate with certificates. HTTP paths are known only after the TLS handshake. Therefore nginx will request an OPTIONAL client certificate at the server level, then require ssl_client_verify=SUCCESS for both /staff and /staff/ (including descendants), with a generic denial otherwise. Do not attempt a path-specific TLS handshake or rely on TLS renegotiation. Public visitors without a certificate can still access /. An invalid certificate that is supplied can cause a connection-level failure even on a public URL; public access is guaranteed for visitors who supply none.

Proposed ssl_verify_depth=2 supports leaf -> Issuing -> Root; test the actual chain/depth semantics. ssl_client_certificate holds trusted CA material; ssl_crl holds current PEM CRLs. Record the verified subject/serial as identity; display escaped identity text only, never trust a client HTTP identity header. Normalize paths and test /staff, /staff/, encoded paths and traversal. No fallback to anonymous staff access. Authentication failures log diagnostic reason internally but return a generic page. CRL refresh, resumption policy and post-revocation reconnection tests follow the PKI plan.

IKEv2 message sequence

I=gw-branch.g03.scp.lab at 172.16.3.20; R=gw-hq.g03.scp.lab at 172.16.3.10. IKE_SA_INIT negotiates crypto and DH; IKE_AUTH authenticates identities/certificates and creates the first CHILD_SA. SK{...} denotes IKE-encrypted and integrity-protected payloads, not application TLS.



SAi1/SAr1 contain selected IKE proposals; KEi/KEr are ephemeral DH shares; Ni/Nr are fresh nonces. SKEYSEED and IKE SK_* keys derive from DH and nonces using the IKEv2 PRF; AUTH binds identities to the initial exchange and signed data. Message IDs/sequence windows and authenticated encryption protect subsequent exchanges from replay. CERTREQ requests acceptable CA; never accepts an arbitrary Root supplied by the peer.

Proposed IKE: aes256gcm16-prfsha384-ecp384; ESP: aes256gcm16-ecp384. Certificates ECDSA P-256 as profiled. Authentication is public-key only; no PSK. Pin remote identity exactly to gw-hq.g03.scp.lab or gw-branch.g03.scp.lab and require valid chain, SAN identity and revocation. TSi=10.3.2.0/24, TSr=10.3.1.0/24; reverse at HQ. Tunnel mode only. Do not broaden selectors to 0.0.0.0/0.

PFS means a compromised long-term key cannot decrypt recorded sessions. The initial CHILD_SA derives from the IKE exchange's DH. Subsequent CREATE_CHILD_SA rekeys must include fresh ECDH (ecp384), not merely claim separate initial CHILD DH. Proposed child rekey 45 min, hard lifetime 60 min; IKE rekey 3 h,

hard lifetime 4 h; DPD delay 30 s and bounded retry/timeout policy to be verified against strongSwan behavior. Exact proposal support and timers remain subject to runtime checks.

Final firewall permits WAN UDP 500/4500 and ESP only, drops unmatched inbound and clear LAN-to-LAN forwarding, and requires outbound/inbound IPsec policy for selectors. Bring tunnel up automatically only in M3. In M1 no swanctl.conf exists at the fixed gateway paths and no IKE service is launched; scoped HTTP baseline bypass is deliberate and not final hardening. Tunnel-loss and daemon-stop tests must prove fail-closed behavior later.

Kerberos-style draft: notation and keys

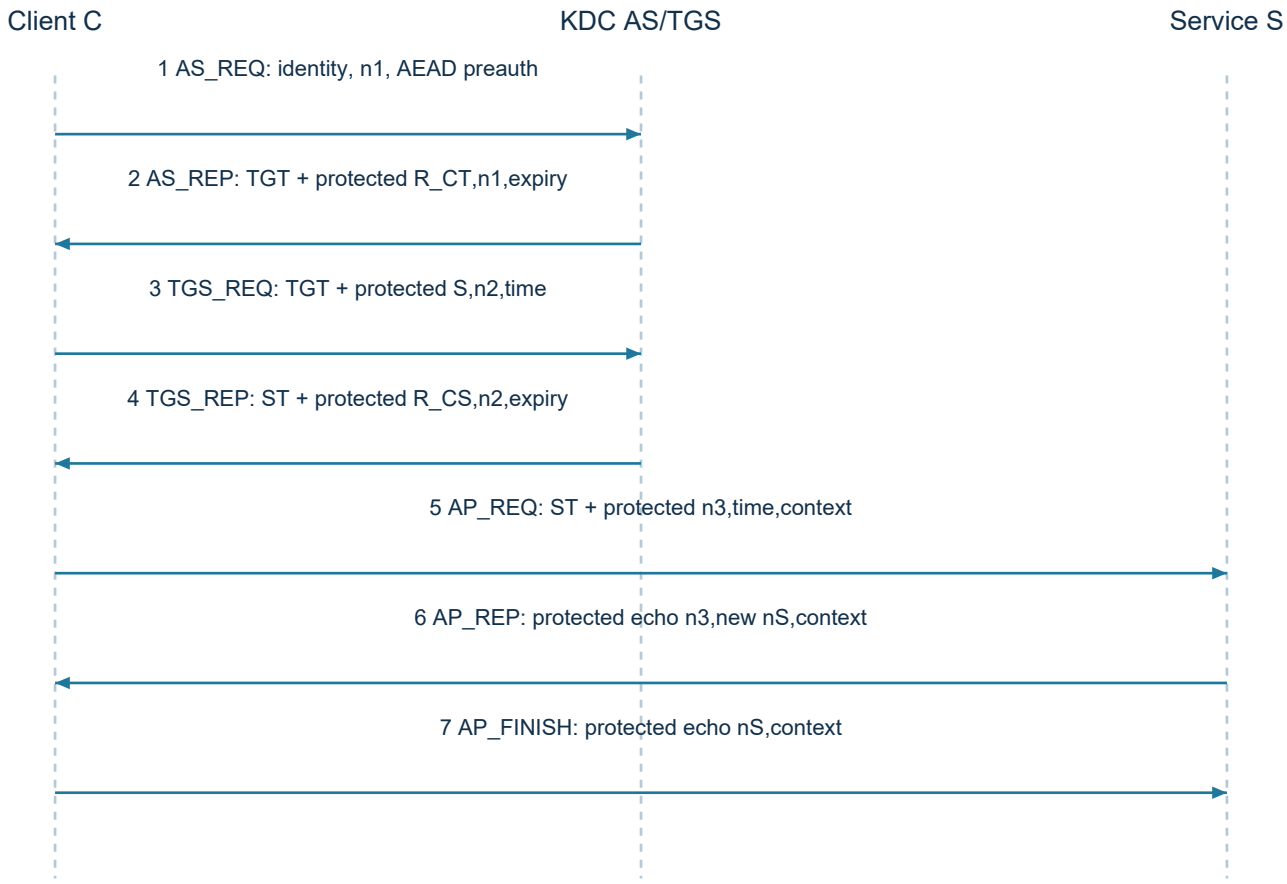
This is an educational custom protocol inspired by AS/TGS/AP, not interoperable Kerberos V5 and not a claim to implement RFC 4120. AS=Authentication Server and TGS=Ticket Granting Server, both roles on kdc TCP 8800. AP=Application exchange with service S on web-hq TCP 8801. C is a staff principal on client-br.

K_C is a unique per-principal long-term key; K_T is the KDC-only TGT-wrapping key; K_S is a service long-term key shared only by KDC and S. Provision them locally, outside Git; never transmit them. For the required wrong-password test, derive K_C with scrypt from a lab password and public per-user salt; return generic errors and rate-limit. Proposed scrypt N=32768,r=8,p=1 and 32-byte output require resource testing. Password-derived challenge responses can permit offline dictionary attacks if captured; use strong lab passphrases and document this residual limitation. No claim to a PAKE.

E_K[type,C,dst,fields] means AES-256-GCM with a unique 96-bit encryption nonce plus authenticated ciphertext. Associated data (AAD) binds protocol version, message type, sender, receiver and request ID using canonical length-prefixed encoding. Derive direction/type-specific AEAD keys from K using HKDF-SHA-256 and distinct labels; reject unknown versions/types/fields. Encryption nonces differ from challenge nonces n1/n2/n3. A proposed persistent nonce counter per key plus process-safe allocator avoids reuse; rotate keys before counter reset/overflow. Restart/recovery semantics must be implemented and tested before security claims.

R_CT and R_CS are fresh random 32-byte seeds for client/TGS and client/service session keys. K_CT=HKDF(R_CT, salt=tgt_id, info=version|C|TGS|expiry); K_CS=HKDF(R_CS, salt=st_id, info=version|C|S|expiry). Distinct derived keys protect authenticators and key-confirmation directions. IDs/nonces come from secrets; request challenge nonces are 128 bits. Time is UTC seconds; initial skew window +/-60 s, TGT lifetime 10 min and service lifetime 5 min capped by TGT. These are draft local choices, not spec constants.

AS/TGS/AP full draft sequence



1. C -> AS: version,C,n1,req1, E_KC[AS_PREAUTH,C,AS,{C,n1,req1,tC}]. AS validates principal and AEAD before accepting freshness; known/unknown principal errors are identical. Public salt provisioning does not disclose K_C. Do not insert unauthenticated IDs into the trusted replay cache.

2. AS -> C: TGT, E_KC[AS_REP,AS,C,{n1,req1,R_CT,tgt_id,issued,expires,TGS}]. TGT=E_KT[TGT,AS,TGS,{C,TGS,R_CT,tgt_id,issued,expires}]. C checks its challenge and derives K_CT. C cannot decrypt or modify TGT. AS records authenticated request replay until its freshness window expires.

3. C -> TGS: req2,S,TGT, E_KCT[TGS_AUTH,C,TGS,{C,S,tgt_id,req2,n2,tC2}]. TGS decrypts TGT, checks destination/lifetime and authenticated request identity, freshness and replay cache. Requested S must be authorized and bound in authenticator/AAD.

4. TGS -> C: ST, E_KCT[TGS_REP,TGS,C,{S,n2,req2,R_CS,st_id,issued,expires}]. ST=E_KS[ST,TGS,S,{C,S,R_CS,st_id,issued,expires}]. C checks n2, S and expiry then derives K_CS. S remains the only service able to open ST.

5. C -> S: req3,ST, E_KCS[AP_REQ,C,S,{C,S,st_id,req3,n3,tC3}]. S checks ticket, identities, expiry, time and atomic replay-cache insert keyed by st_id,C,req3,n3 AFTER authentication. Cache retention lasts ticket expiry plus skew; authenticate before application side effects.

6. S -> C: E_KCS[AP_REP,S,C,{st_id,req3,n3,nS,tS,context}]. Echo n3 proves S possesses K_CS; bind session context and new server challenge nS. C validates before considering S authenticated.

7. C -> S: E_KCS[AP_FINISH,C,S,{st_id,req3,nS,context}]. S consumes a pending challenge once and marks the session established. Neither side grants application actions until mutual confirmation. Both derive application keys with a separate HKDF label/context; use monotonic sequence numbers and replay windows for later application records.

Replay, errors and draft validation

Reject duplicate valid AS/TGS/AP requests atomically; parallel duplicate delivery must not bypass the cache. Cache state persists through restart or invalidate all active tickets by rotating wrapping/session state; document the chosen recovery policy. Accept no authenticator outside skew or ticket validity. Synchronize lab clocks from trusted host, detect large jumps, and fail rather than silently enlarge windows. Expired tickets and stale challenges cannot establish sessions. Rate-limit and bound pending/cache state without evicting still-live replay entries; refuse new sessions when capacity is exhausted.

Wrong AEAD tag, wrong key, wrong destination, changed ticket ID, stale time, changed nonce and duplicate AP_FINISH must be refused with generic errors and sanitized logs. Planned weak no-freshness variant lives only under attacks/replay/ in M3. Test T12a on weak variant then T12b using the same message on fixed variant. M1 supplies design only; framing (bounded length-prefixed messages, initial 64 KiB cap), nonce persistence, scrypt performance, key lifecycle, clock recovery and strongSwan EKU compatibility remain draft decisions for later tests.

References

Assignment sections 6-10. TLS sequence: RFC 8446 sections 2 and 4, https://www.rfc-editor.org/rfc/rfc8446 . IKE exchanges/key derivation: RFC 7296 sections 1-2, https://www.rfc-editor.org/rfc/rfc7296 . Kerberos vocabulary: RFC 4120, https://www.rfc-editor.org/rfc/rfc4120 . nginx certificate/depth/CRL directives: https://nginx.org/en/docs/http/ngx_http_ssl_module.html . strongSwan proposal and identity options: https://docs.strongswan.org/docs/latest/swanctl/swanctlConf.html . Version-specific behavior must be checked on the Ubuntu image later.

STRIDE Threat Model

Group 03 | M1 design | Planned checks, not executed attacks

Method and assets

STRIDE: Spoofing identity, Tampering data, Repudiation of actions, Information disclosure, Denial of service and Elevation of privilege. Likelihood (L) and impact (I) are qualitative Low/Medium/High ratings for the baseline or pre-control state, not measured probabilities. Controls reduce risk but do not prove implementation. Assets: offline Root/Issuing keys, gateway identity and tunnel policy, portal/staff identity, KDC keys/tickets, evidence and repository integrity. Authorized attacker is WAN-only at 172.16.3.66; tests remain inside this lab.

Lab-specific threat register

ID / component / STRIDE	Scenario and L / I	Control and planned verification
S01 / WAN HTTP / Information disclosure	Attacker observes client-br HTTP body across gateway WAN before VPN. L High / I High.	M1 documents real known plaintext baseline; later ESP plus TLS. Compare M1 vs T7 PCAP with same marker; absent marker alone is not proof without successful client response.
S02 / portal DNS + TLS / Spoofing	Lab name override sends portal client to attacker presenting rogue-CA leaf. L High / I High.	Root trust + SAN validation; never curl -k in final tests. T5 refusal; isolated insecure comparison only in attacks/. No real OS/browser trust change.
S03 / gateway IKE_AUTH / Spoofing	Attacker uses valid staff clientAuth certificate as gw-branch or a rogue gateway chain. L Medium / I High.	Pin exact peer SAN identity, trusted chain, gateway purpose and CRL. T8 fails for both cases with strongSwan logs; test same-CA wrong identity explicitly.
S04 / staff CRL / Elevation of privilege	Revoked staff03 authenticates because nginx worker uses stale CRL or resumed TLS session. L Medium / I High.	Monitor nextUpdate, atomic PEM deployment/reload, fail on unknown status, expire resumptions/connections. T4 plus expired/missing CRL and reconnect tests.
S05 / offline Root key / Tampering	Root key accidentally enters /work mount; compromised service can sign an alternative Issuing CA. L Medium / I High.	Root outside repo/build context/mounts, encrypted offline, mode 600, restricted backup. Inspect mounts/storage, full-history scan T13, certificate-chain/pathlen tests.
S06 / AP authenticator / Spoofing	Attacker replays captured valid service login to repeat an action. L High / I High.	AEAD, ticket identity binding, +/-60 s window, atomic replay cache and one-time nS confirmation. T12a weak success; T12b fixed refusal, concurrent duplicate and restart tests.
S07 / tickets + routing / Tampering	Attacker changes service ID, ticket expiry or AAD fields, or swaps a TGT for a service ticket. L Medium / I High.	Domain-separated AEAD keys/AAD, canonical encoding, destination/type validation. Modified-byte and cross-role ticket negative tests in T11/T12b.

ID / component / STRIDE	Scenario and L / I	Control and planned verification
S08 / gateway forwarding / Information disclosure	IKE daemon stops and Linux routes campus traffic in clear. L High / I High.	Final IPsec-policy-required firewall; no blanket established rule bypass for protected selectors. T9 daemon stop while client sends known body; WAN capture must show no clear packet. M1 exception explicitly retired in M3.
S09 / TLS + IKE negotiation / Tampering	Misconfigured peer forces obsolete TLS, non-AEAD/non-PFS suites or weak IKE proposal. L Medium / I High.	Explicit version/proposal allowlist and PFS. T6 and SR13 weak IKE offer refusal; testssl no HIGH/CRITICAL.
S10 / KDC AS + replay cache / Denial of service	Forged AS traffic exhausts password KDF/AEAD CPU or cache; clock jump invalidates all tickets. L High / I Medium.	Bounded message sizes/rate limits, verify before cache insertion, retain live replay entries, trusted clock/skew, capacity fail-closed. Load, malformed-frame and time-jump tests in isolated lab.
S11 / test logs + Git / Repudiation	Claimed PASS or teammate contribution has no dated command/output or traceable commit. L Medium / I Medium.	Record actual tester, expected/actual, UTC time and artifact hash; reviewed commits, no invented attribution. Inspect unified log and contribution record; T13.
S12 / /staff/ access boundary / Elevation of privilege	Anonymous caller bypasses staff check using /staff, encoded path or forged identity header. L Medium / I High.	Cover normalized /staff and subtree, require verified cert, escape display identity, distrust HTTP headers. T3/T4 path matrix with no certificate and revoked certificate.
S13 / .env / keys / Information disclosure	First commit or later tag exposes private key, PSK, p12 or TLS session key log in Git history. L Medium / I High.	.gitignore before staging, review tracked paths and full-history content scan before every milestone. T13; if leak occurs rotate credentials and repair history before any release.
S14 / Docker host boundary / Elevation of privilege	Overbroad host networking, Docker socket or privileged container enables experiments outside lab. L Medium / I High.	Three internal non-masqueraded networks, no ports/host network/socket/privileged mode; explicit capabilities for network setup/capture and process/file ownership. Inspect Compose caps/network options and no default routes. Host admin remains trusted.

Residual risk and priorities

Highest priorities before runtime acceptance: actual isolation/routes, genuine WAN plaintext capture, role-restricted secret placement and resolving replacement-kit acceptance. Baseline has no cryptographic source authentication and remains intentionally observable. Future TLS does not hide metadata; VPN does not protect LAN plaintext; CRL distribution can be blocked; password-based preauthentication can leak an offline guessing oracle. The custom protocol is educational and needs adversarial review; do not present draft design as production assurance.

Team and Delivery Plan

Group 03 | Prepared 2026-11-07 | M1 only

Confirmed membership

Student ID	Confirmed original name
2350906014	الاء يزن احمد الزعبي
2300906110	بغداد ثامركساب بني خالد

Names are preserved exactly as supplied in Arabic; no official English spelling has been invented. Student IDs are used as unambiguous labels elsewhere. Instructor approval for the two-member exception is reported by the user; no written approval artifact was supplied. This does not imply approval of the replacement Starter Kit or a deadline extension.

Confirmed planned responsibilities

The user confirmed the role allocation below. These are future responsibilities, not completed contribution claims. IDs map to the original names above.

Workstream	Proposed owner / reviewer	Completion rule
Requirements, topology and document integration	2350906014: implementation/integration. 2300906110: consistency review. IDs map to original names above.	Reviewer records actual comments/date only after reading all six PDFs and cross-checking lab addresses.
Baseline lab and evidence	2350906014: operate and document. 2300906110: independently repeat HTTP and capture checks.	Actual operator/tester and commands recorded; no attribution before execution.
Git and release	2350906014: prepare commits. 2300906110: review staged diff and evidence.	Both understand scope and can explain design; final tag only after all M1 gates.
Later milestones	Allocate after explicit user instruction.	No M2/M3 implementation begins under this M1 task.

The user may perform most implementation. Teammate review/testing is credited only after it occurs. Each member must understand PKI, VPN, protocol and evidence for individual discussion (assignment section 14).

Actual preparation vs planned activity

State	Work
Actual	All 11 assignment pages were reviewed, the empty SCP workspace and available tools checked, and group/membership details confirmed with the reported two-member approval.
Actual preparation	Editable English M1 designs and baseline lab files are prepared. Document preparation is not proof of completed member review or runtime testing. Generated outputs/static results are listed in README and static review log.

State	Work
Actual environment and baseline	WSL/Docker installed; image built; six healthy nodes and lab-only routing/isolation checked. Real WAN HTTP PCAP captured on gw-hq; frames 4/6 show request/readable response. Scripted execution requested by 2350906014; no independent member retest claimed.
Planned, not performed	Baghdad's independent review/retest; any individual confirmation of the scripted evidence.
Pending acceptance	Project-local lab/ replacement, original deadline handling, and Public repository instead of the required private visibility. No instructor approval is inferred.
Future, excluded	PKI issuance, crypto tool, TLS deployment, VPN, KDC implementation and attacks belong to later milestones.

Schedule and dependencies

Assignment dates: M1 06/11/2026; M2 20/11/2026; M3 11/12/2026; M4 25/12/2026. On preparation date 07/11/2026, M1's original deadline has passed. Confirm late-submission handling with instructor; no new date or waiver is assumed.

Completed technical sequence: environment setup -> manual restart -> image build -> six-node/isolation checks -> HTTP and actual WAN capture -> recorded frames/results. Remaining sequence: member review/retest -> instructor clarification of listed exceptions -> final secret/history review -> annotated M1 tag only after all gates pass. This is an order of work, not a new deadline.

Git, branches and releases

Assignment requires an independent private SCP repository. The team explicitly requested Public visibility because the instructor's account is unknown; public reading is verified, but approval of that exception is pending. Branch main holds M1; future short branches use factual commits and real review. No fabricated teammate authorship or review. Secrets never enter Git; Root storage stays outside repository/mounts.

Before M1: review staged paths/content, scan the full reachable Git history and current files for secret markers/forbidden paths, inspect PCAP contents for real credentials, and verify all A1-A7 gates. Scan is heuristic, supplemented by manual review. An annotated timestamped tag named M1 is created and pushed only after every mandatory item including actual runtime/PCAP is complete. No placeholder M1 tag or release now.

Repository: https://github.com/alaayznn/scp-secure-inter-campus-g03 . It can be read without a GitHub account. Public reading solves access, not the assignment's private-repository requirement. The one-file M1_Submission.pdf includes the repository link and six required documents; it does not replace the still-pending release tag or instructor acceptance of exceptions.

Handover checklist

Each member should explain: why two CAs and offline Root; why at least three staff certificates for two people; what SAN/KU/EKU constrain; why VPN plus TLS; why the M1 HTTP capture must be readable; why gateway peer identity is pinned; why nonce/timestamp alone is insufficient without replay state; how fresh CRLs and failure policy work; what was actually tested and what is still planned. A review entry needs real name/ID, date, scope, findings and disposition. None is claimed here.